

Pentesting protokol – OWASP- Top 10

Na základě <https://owasp.org/www-project-top-ten/> jsme projeli náš projekt na zapisování rozvrhovaných akcí.

Při našem penetračním testování jsme narazili na tyto 4 kritické zranitelnosti na straně STAGu A1

6. Manipulace s přístupovým tokenem (Stag ticket)

A7

7. Exposes session identifier in the URL (Problematika po přihlášení ze STAGu – vrací v URL)

8. Reuse session identifier after successful login (Stag vrací stejný ticket po dobu přihlášení na STAGu)

9. Does not correctly invalidate session Ids. Auth tokens aren't properly invalidated during logout/period of inactivity. (Problematika invalidace ticketu na straně stagu)

Všechny tyto kritické zranitelnosti vznikají na straně informačního systému STAG a to jak na straně demo-stag-zcu.cz, tak i na straně portal.ujep.cz

Tyto problémy vznikají v závislosti na REST API STAGu, kde endpoint invalidate vždycky vrací OK (200) i v případě, že se tak nestalo. Nicméně ticket zůstává validní po době STAG session i po odhlášení uživatele z naší aplikace a zavolání na invalidate endpoint.

Rozbor našeho testování a našich observací je uložen v .xlsx souboru na této stránce:

https://docs.google.com/spreadsheets/d/1jCRE75LG0D_tdq44sKS85znvD0Qzcn7Rt35DvjIXUuw/edit?gid=0#gid=0

Sepsáno týmem: Alex Schönfelder, Martin Kopecký, Adam Legner, Daniel Říha